Documento de Definição de Projeto: API de Detecção de Fraudes em E-commerce

Disciplina: Tópicos Especiais

Integrantes:

- Caio Leonel Oliveira Rosa
- Diego Juan Figueiredo de Santana
-
-

1. Informações do Negócio

Visão Geral: O projeto consiste no desenvolvimento de um microsserviço (API REST) focado em mitigar prejuízos financeiros em plataformas de comércio eletrônico. A API atuará como um intermediário crítico no fluxo de checkout, avaliando cada transação em tempo real antes de seu processamento financeiro.
Problema a ser resolvido: Lojas virtuais enfrentam constantes ataques de fraudadores que utilizam dados financeiros roubados. Quando a compra fraudulenta é contestada pelo titular do cartão, o lojista arca com o prejuízo do estorno (chargeback) e a perda do produto físico.
Solução Proposta: Uma API de integração simples que recebe os dados da tentativa de compra e retorna uma avaliação instantânea, indicando se a transação deve seguir o fluxo, ser bloqueada ou enviada para análise manual humana.

2. Regras de Negócio (RN)

Abaixo estão as diretrizes lógicas que a aplicação backend deverá seguir estritamente para garantir a confiabilidade e a alta disponibilidade da operação.

Código	Descrição da Regra
RN01	Uma transação só poderá ser processada pela API se a requisição contiver um token de autenticação de cliente válido e não expirado.
RN02	Transações que o modelo de inteligência artificial classificar com um score de risco igual ou superior a 85% devem ter seu processamento financeiro automaticamente bloqueado.
RN03	Transações com score de risco entre 60% e 84% deverão ter o status alterado para "Em Revisão", aguardando intervenção manual no painel administrativo do lojista.
RN04	O sistema não deve armazenar de forma persistente, em nenhum banco de dados relacional (ex: MySQL) ou não relacional, o código de segurança (CVV) do cartão, atuando em conformidade com o padrão PCI-DSS.
RN05	Caso o endereço de entrega seja divergente da unidade federativa atrelada ao IP de origem do comprador, o score de risco deve sofrer um incremento obrigatório estipulado pela IA.
RN06	A validação de fraude não deve bloquear a operação principal de vendas. Caso o motor de IA não responda dentro de um timeout aceitável (ex: 2 segundos), a transação deve ser aprovada temporariamente ou enviada para "Em Revisão", assegurando que o checkout não fique indisponível.

3. Segurança e Controle de Acesso

Dada a criticidade dos dados transacionados, a arquitetura do projeto incorporará as seguintes práticas avançadas de segurança da informação:

- **Autenticação da API:** A validação de quem consome a API será feita através de tokens JWT (JSON Web Tokens). Cada e-commerce cliente terá credenciais únicas para gerar tokens de curta duração, assegurando que apenas sistemas registrados façam chamadas aos endpoints.
- **Proteção de Dados Sensíveis e Tokenization (LGPD):** Dados de identificação pessoal (CPF, Nome) e partes mascaradas de cartão de crédito não serão guardados em texto pleno. O banco de dados MySQL utilizará o padrão de Tokenization, onde um hash ou token irreversível substitui o dado sensível primário, em conjunto com criptografia forte (ex: AES-256) para metadados, minimizando severamente a superfície de vazamento de dados.
- **Mitigação de Ataques:** A aplicação contará com limites de requisição por segundo (Rate Limiting) para evitar ataques de negação de serviço (DDoS) ou força bruta na submissão de transações via bots.
- **Auditoria Assíncrona:** Registro imutável de todas as ações no sistema, armazenando metadados como endereço IP, data/hora e o endpoint acessado. Para não degradar a performance da API principal, a gravação dos logs será enviada para o banco de dados através de processamento em background (Assincronicidade/Filas).

4. Utilização da Inteligência Artificial (IA)

O motor de decisão do projeto será fundamentado em um modelo de aprendizado de máquina (Machine Learning), que substituirá análises baseadas apenas em regras estáticas.

- **Técnica Utilizada:** Análise preditiva e classificação binária treinada com dados históricos.
- **Aplicação Prática:** Ao receber um payload com os dados da compra, o backend delegará a avaliação das variáveis ao modelo de IA integrado à arquitetura.
- **Variáveis (Features) Avaliadas pela IA:**
    - **Velocidade de Checkout:** Tempo decorrido entre o acesso à página e o pagamento (bots tendem a ser irrealmente rápidos).
    - **Geolocalização:** Cruzamento entre o IP de acesso, o endereço de cobrança e o endereço de entrega.
    - **Histórico Comportamental:** Ticket médio do usuário e recorrência de compras no último mês.
- **Retorno:** A IA devolverá um score probabilístico (0 a 100%), que será consumido pela API para aplicar as regras de negócio listadas na seção 2.

5. Arquitetura e Resiliência Estratégica

Para garantir que o micro serviço possua nível corporativo de estabilidade, os seguintes padrões arquiteturais serão aplicados:

- **Padrão Circuit Breaker:** Implementado no ponto de integração entre o Backend e o serviço de Inteligência Artificial. Se o serviço de IA apresentar instabilidade ou sobrecarga, o circuito se "abre", evitando que as chamadas fiquem presas em timeout e derrubem os recursos da aplicação (garantia da regra RN06).
- **Event-Driven / Assincronicidade:** Processos secundários como gravação no log de auditoria, atualizações de métricas e separação de dados para retreinamento da IA não ocorrerão na thread principal da requisição web, garantindo tempos de resposta ultra rápidos para o checkout da loja parceira.